

Comunicación "A" 7724 — Requisitos mínimos de gestión de identidad digital

Banco Central de la República Argentina. A las entidades financieras, a las empresas no financieras emisoras de tarjetas de crédito y a los proveedores de servicios de pago.

1. Objeto

Establecer los requisitos mínimos que las entidades deben observar en la gestión de la identidad digital de sus clientes y usuarios, comprendiendo el alta, la autenticación, la recuperación de credenciales y la baja.

2. Autenticación reforzada

Toda operación que implique movimiento de fondos, alta de destinatarios de transferencia, modificación de límites operativos o cambio de datos de contacto requiere autenticación con al menos dos factores independientes, pertenecientes a categorías distintas entre las siguientes:

- Algo que el usuario conoce: contraseña, número de identificación personal.
- Algo que el usuario posee: dispositivo registrado, token físico o lógico, código de un solo uso.
- Algo que el usuario es: característica biométrica.

Dos elementos de la misma categoría no constituyen dos factores independientes. En particular, una contraseña más una pregunta de seguridad no satisfacen este requisito.

3. Código de un solo uso

Cuando se utilice un código de un solo uso enviado por mensaje de texto o correo electrónico, la entidad deberá considerar las limitaciones de ese canal y establecer controles compensatorios ante la sustitución fraudulenta de la línea del usuario. El código tendrá una vigencia máxima acotada y no podrá reutilizarse.

4. Biometría

Cuando se utilice un factor biométrico, la entidad deberá implementar mecanismos de detección de prueba de vida. El cotejo de una imagen estática no satisface el requisito. Los datos biométricos se almacenarán como plantilla y con cifrado, y no podrán utilizarse para finalidades distintas de la verificación de identidad.

5. Recuperación de credenciales

El proceso de recuperación de credenciales no podrá tener un nivel de seguridad inferior al del proceso de autenticación que restituye. La entidad no restablecerá credenciales por canales que no permitan verificar la identidad del solicitante con el mismo estándar.

6. Registro y conservación

Las entidades deberán conservar el registro de los eventos de autenticación, de sus fallos y de las recuperaciones de credenciales, por el plazo establecido en las normas sobre conservación de

documentación digital.

7. Vigencia

Las disposiciones de la presente comunicación son de aplicación a partir de la fecha indicada en su publicación. Las entidades deberán adecuar sus procedimientos internos e informar al Superintendente el grado de avance de la adecuación.